

GRC Portfolio – Nkanyiso Nene					
Governance, Risk & Compliance ISO 27001 Vendor Risk BCP/DR Audit Readiness					
1. Vendor Risk Assessment Questionnaire					
Objective: Evaluate third-party risk prior to onboarding and during ongoing monitoring.					
Scope: All vendors with access to company data, systems, or facilities.					
Key Assessment Areas & Scoring					
	Assessment Area	What I Evaluate	Risk Indicators		
1	Company & Service	Legal entity, service description, data access, 4th parties, data location	Data stored offshore, unclear 4th party use		
2	Security Governance	Policies, CISO role, risk assessments, ISO 27001/SOC 2 certs	No policy framework, expired certs		
3	Access Controls	MFA, RBAC, logging, offboarding process	Shared accounts, no MFA, no offboarding		
4	Data Protection	Encryption at rest/in transit, retention/deletion, breach history, POPIA/GDPR	Unencrypted PII, no data deletion process		
5	Incident Response & BCP	IR plan, notification SLA, BCP/DR test results	No IR plan, no BCP testing in 24 months		
6	Network Security	Vuln scans, pen tests, patching, segmentation	Critical vulns unpatched >30 days		
7	Legal & Compliance	Regulatory compliance, fines, audit rights, DPA clauses	No DPA, refuses audit rights		
8	Financial Stability	Financials, cyber insurance, annual turnover	No cyber insurance, negative equity		
Scoring Method					
1= Does not meet / High risk					
2 = Partially meets / Medium risk					
3 = Fully meets with evidence / Low risk					
Weighted scoring applied per area based on criticality					
Risk Rating:					
≥80% = Low Risk – Approve with standard monitoring					
60-79% = Medium Risk – Approve with conditions + remediation plan					
<60% = High Risk – Reject or require remediation before onboarding					
Deliverable: Excel tracker with auto-calculated risk rating, weighted score, and auto-generated remediation actions.					
Use case: I built this to prioritize vendors supporting Tier 1 functions from my BIA.					
2. Business Impact Analysis					
Objective: Identify critical business functions and define recovery objectives to prioritize BCP/DR resources and vendor oversight.					
Process					
1. Inventory business functions across departments					
2. Assess impact of disruption over time: Financial, operational, reputational, legal, safety					
3. Define RTO and RPO for each function					
4. Map dependencies: People, systems, data, vendors, facilities					
5. Assign priority tier: Tier 1 Critical, Tier 2 Important, Tier 3 Non-critical					
Sample Output					
Business Function	Impact if Down 24h	RTO	RPO	Dependencies	Priority
Payroll Processing	High financial/legal impact, regulatory breach risk	2 days	1 day	SAP, HR Team,	Tier 1
Customer Support	Medium operational impact, customer churn risk	4 hrs	4 hrs	CRM, Telephony	Tier 2
Marketing Website	Low financial impact, reputational risk	7 days	1 day	Web host, CMS,	Tier 3
Use: Drives BCP strategy, vendor risk prioritization, and budget allocation. Functions marked Tier 1 get priority for vendor due diligence and DR testing.					
3. Business Communication Skills for GRC					
Objective: Translate technical risk into actionable business decisions for non-technical stakeholders.					
Core Competencies					
1. Clarity & Conciseness: Lead with impact and recommendation. No jargon for execs.					
2. Audience Adaptation: Tailor message for execs, technical teams, auditors, regulators.					
3. Written Communication: Structured reports, emails, policies with clear headers, bullets, next steps.					
4. Facilitation: Run risk workshops, BIA sessions, manage stakeholder conflict to reach decisions.					
5. Risk Communication: Frame issues as business impact:					
"If vendor X loses data, we face POPIA fines up to R10M and 30-day outage. My recommendation is to suspend integration until they provide SOC 2 Type II."					
Principle: A CEO should understand the risk and decision in 30 seconds.					

4. Audit Preparation Document				
Objective: Organize evidence and processes to ensure smooth internal and external audits against ISO 27001, POPIA, and internal policy.				
Key Evidence Areas				
1. Governance: Policies, approval dates, review cycles, policy owners				
2. Risk Management: Risk register, methodology, treatment plan, management review minutes				
3. Access Management: User lists, quarterly access reviews, joiner-mover-leaver process, MFA evidence				
4. Operations: Change management logs, vuln scans, pen tests, patching records, backups, SIEM logs				
5. Incident & Compliance: Incident register, IR reports, BCP test results, data subject request log, training records				
6. Third Party: Vendor list, risk assessments, contracts, DPAs, ongoing monitoring reports				
90-Day Timeline				
90 days: Define scope, gap analysis, assign owners				
60 days: Collect evidence, run control tests and access reviews				
30 days: Compile evidence folder, conduct mock audit, brief staff				
1 week: Final check, set up war room, prepare management briefing				
Evidence Standard: Policy + Procedure + Proof. "Informal" or "we just do it" is not acceptable to auditors.				
5. Portfolio Integration				
These artifacts work as a system, not in isolation:				
1. Business Impact Analysis identifies critical functions and recovery objectives. This tells me what matters most.				
2. Vendor Risk Assessment evaluates vendors supporting those critical functions. High-risk vendors supporting Tier 1 functions get escalated.				
3. Audit Preparation demonstrates controls are designed and operating effectively for those risks.				
4. Business Communication ensures risks and recommendations are understood and acted on by leadership.				
Competencies Demonstrated				
Risk assessment, vendor management, BCP/DR planning, audit readiness, stakeholder communication, ISO 27001 & POPIA application, GRC framework execution.				

